PORTFÓLIO DIDÁTICO • MÓDULO 01

PHISHING NOS DIAS ATUAIS

Como reconhecer a isca, interromper a pressa e escolher o próximo passo com segurança.

IDEIA-CHAVE

A mensagem pode mudar de canal e aparência. O objetivo continua sendo influenciar uma ação: clicar, abrir, informar, pagar ou aprovar.

Segurança Digital na Prática · BBS One
Público geral · leitura estimada: 12 minutos · revisão de fontes: 16 out. 2026

01 | Entenda a mecânica

Phishing é uma fraude que combina uma mensagem-isca com engenharia social para levar alguém a entregar dados, acessar uma página falsa, instalar algo ou autorizar uma ação. O atacante explora confiança, curiosidade, medo, urgência ou oportunidade. A história muda; a pressão para agir sem verificar é a pista recorrente.

O que o golpista tenta obter

DADO / AÇÃO	O RISCO
Senha ou código temporário	Acesso à conta e possibilidade de se passar pela vítima.
Pagamento, PIX ou cartão	Desvio de dinheiro ou captura dos dados de pagamento.
Clique, download ou comando	Instalação de malware, roubo de sessão ou controle do dispositivo.
Aprovação de MFA	Confirmação de uma tentativa de login iniciada por outra pessoa.

A sequência em cinco passos

1. Escolher um alvo ou grupo. 2. Criar contexto convincente. 3. Pedir uma ação rápida. 4. Capturar dados ou induzir pagamento/acesso. 5. Usar os dados, vender acesso ou tentar novo golpe.

Importante: erros de português ajudam a desconfiar, mas mensagens bem escritas também podem ser fraudulentas. Aparência profissional, logotipo e cadeado HTTPS não provam que a página pertence à organização.

02 | A isca chega por vários caminhos

E-mail continua comum, mas a mesma abordagem pode chegar por SMS, WhatsApp, redes sociais, chamadas de voz, anúncios ou QR codes. Uma conversa já conhecida também pode ser usada se uma conta legítima tiver sido comprometida.

Formatos para reconhecer

E-mail e anexos

Aviso de conta, documento, nota fiscal, currículo ou cobrança. Pode conter link de login falso ou arquivo inesperado.

SMS e WhatsApp

“Pendência”, entrega, benefício ou bloqueio. O link leva a página falsa, cobrança PIX ou conversa com impostor.

QR code (quishing)

O código esconde o endereço até ser lido. Pode aparecer em cartaz, e-mail, menu, boleto ou etiqueta adulterada.

Voz e vídeo

Alguém se apresenta como suporte, gestor ou familiar e pede código, transferência ou sigilo. Voz/imagem familiar não substitui confirmação.

MFA por notificação

Pedidos de aprovação que não foram iniciados por você; repetição pode cansar e induzir um toque automático.

Busca e anúncios

Resultado patrocinado ou site parecido pode imitar serviço real. Digitar/usar favorito oficial reduz a exposição a links recebidos.

O CERT.br alerta que links e QR codes podem levar a páginas falsas ou malware; se a origem não estiver clara, não leia o código.

03 | Exemplos brasileiros recentes

Casos publicados por órgãos oficiais ajudam a transformar o conceito em sinais observáveis. Eles ilustram padrões e não significam que toda mensagem parecida seja automaticamente falsa: verifique sempre por um canal independente.

Caso 1 · falso serviço ou cobrança do governo

> **O roteiro**
>
> Mensagem de WhatsApp imita representante de órgão público, oferece um serviço ou cobra uma suposta dívida e pressiona para abrir um link e pagar boleto/PIX. O CISC Gov.br alertou em 2026 que essas páginas simulam portais e buscam induzir pagamentos indevidos.

Resposta segura: não use o link recebido. Encontre o serviço digitando o endereço oficial conhecido. Para órgãos do governo federal, confira cuidadosamente o domínio .gov.br; confirme a cobrança no portal oficial ou atendimento publicado nele.

Caso 2 · página falsa encontrada durante uma busca

> **O roteiro**
>
> Alguém pesquisa um serviço público e encontra um link fraudulento em uma campanha que pode até usar uma conta remetente legítima comprometida. O alerta conjunto CISC Gov.br/CTIR Gov publicado em 2026 descreve campanha que abusava da confiança em endereços .gov.br para distribuir malware e roubar dados.

Resposta segura: não conclua que o resultado é confiável só porque apareceu primeiro ou parece oficial. Confira o endereço completo, evite anúncios suspeitos e acesse pelo portal que você já conhece.

Caso 3 · “seu acesso será bloqueado agora”

> **O roteiro**
>
> E-mail ou SMS afirma que há problema urgente e solicita login, código de autenticação ou pagamento para “regularizar”. O alerta pode usar marca conhecida e texto impecável; o objetivo é fazer você atravessar o link até a página do fraudador.

Resposta segura: feche a mensagem e consulte o serviço pelo aplicativo oficial, favorito salvo ou endereço digitado por você. Não responda com senha/código e não aprove pedidos de MFA que não iniciou.

04 | Pausa de 20 segundos

Antes de tocar, responder, pagar ou aprovar, faça uma verificação curta. Uma pista isolada pode ter explicação; várias pistas, especialmente urgência + link + pedido de dado, pedem pausa.

Checklist: PARE

P · Pressão

Tem ameaça, prazo curtíssimo, segredo ou promessa boa demais?

A · Autor

O remetente/telefone é esperado? O endereço e o nome exibido combinam?

R · Rota

A URL é exatamente a oficial? O link veio por canal inesperado?

E · Exigência

Pedem senha, código MFA, instalação, PIX ou aprovação não iniciada?

Faça a checagem fora da mensagem: abra o aplicativo instalado, digite o endereço conhecido ou ligue para o número que consta no cartão/site oficial. Não use telefone ou link fornecido pela própria mensagem suspeita.

E o HTTPS?

HTTPS protege a conexão com aquele domínio, mas não prova que o domínio é legítimo. Um site fraudulento também pode usar HTTPS. Confira o nome do domínio, caractere por caractere, e prefira começar pelo canal oficial.

05 | Hábitos que reduzem o risco

Prevenção funciona melhor quando o caminho seguro é simples e repetível. Use os recursos disponíveis no serviço e siga também as regras da sua empresa.

No dia a dia

• Use senhas únicas e um gerenciador de senhas confiável; não reutilize a senha corporativa.

• Ative MFA. Prefira métodos resistentes a phishing, como passkeys/chaves de segurança, quando o serviço oferecer.

• Nunca compartilhe senha ou código de verificação; não aprove solicitações MFA que você não iniciou.

• Mantenha navegador, sistema e aplicativos atualizados; instale programas só de fontes oficiais.

• Confirme pedidos sensíveis (pagamento, troca de conta bancária, envio de dados) por um segundo canal conhecido.

• Reduza informações públicas desnecessárias: detalhes sobre cargo, viagens e relações podem personalizar golpes.

• No trabalho, reporte mensagens suspeitas pelo procedimento interno, mesmo que não tenha clicado.

> **Regra de ouro**
>
> Se a mensagem pede segredo, senha, código, pagamento ou uma aprovação inesperada, interrompa e confirme por um canal independente.

A MFA ajuda, mas os métodos variam. A CISA recomenda priorizar MFA resistente a phishing. SMS, códigos digitados e notificações push ainda podem ser explorados por engenharia social; siga a orientação da equipe de TI para o método autorizado.

06 | Se clicou, informou algo ou aprovou

Não esconda nem espere para ver se algo acontece. Resposta rápida ajuda a limitar o impacto; agir sem culpa facilita pedir ajuda cedo.

Faça agora, nesta ordem

1. Pare a interação

Não informe mais dados, não pague e não aprove novas solicitações. Feche a página ou conversa.

2. Avise o suporte

No trabalho, contate imediatamente TI/Segurança pelo canal interno conhecido. Informe horário, mensagem, link e ação realizada.

3. Proteja as contas

De um dispositivo confiável, acesse o serviço pelo canal oficial e troque a senha exposta. Troque também onde foi reutilizada; encerre sessões desconhecidas e revise MFA.

4. Trate pagamentos

Se enviou dinheiro ou dados de cartão, contate imediatamente o banco/provedor pelo aplicativo ou telefone oficial e peça orientação para contestar/bloquear.

5. Preserve evidências

Guarde remetente, URL, horário e captura da mensagem conforme a política da organização. Não encaminhe a isca a outras pessoas.

6. Denuncie e acompanhe

Use o recurso de denúncia da plataforma e os canais oficiais aplicáveis. Observe acessos, transações e mensagens enviadas em seu nome.

Se apenas abriu um link mas não digitou dados: feche a página, não baixe/execute arquivos e avise o suporte no contexto de trabalho. Se abriu um arquivo, instalou algo ou executou comandos, informe isso claramente para que o time avalie o dispositivo.

07 | Mini laboratório: qual é o próximo passo?

Leia cada cenário e decida antes de consultar as respostas. Os exemplos são fictícios e não contêm links ativos.

A. “Seu pacote está retido. Pague R$ 4,90 hoje pelo QR code.”

Pergunte: eu esperava uma entrega? Consigo conferir pelo aplicativo oficial da transportadora sem usar esse QR code? Ação: não pagar pelo link recebido; verificar no canal oficial.

B. “Sou do suporte, preciso do código de 6 dígitos para liberar sua conta.”

Pergunte: eu iniciei este atendimento? Ação: nunca compartilhar o código; encerrar e contatar o suporte pelo canal conhecido.

C. O celular exibe vários pedidos MFA, mas você não está tentando entrar.

Ação: rejeitar todos, não aprovar “para parar os avisos” e comunicar suporte/segurança. Trocar a senha pelo portal oficial conforme orientação.

D. Mensagem do gestor pede pagamento urgente e sigilo.

Ação: confirmar por chamada ou canal corporativo já conhecido e seguir dupla aprovação financeira.

Fontes para continuar estudando

CERT.br. Phishing e outros golpes, Cartilha de Segurança para Internet. https://cartilha.cert.br/guardiao/fasciculo-phishing-golpes-egc.pdf (acesso em 16 out. 2026).

CISC Gov.br. Golpistas enviam mensagens no WhatsApp se passando por entidades do governo, publicado em 13 fev. 2026, modificado em 8 abr. 2026. https://www.gov.br/cisc/pt-br/alertas-de-golpes-digitais/golpistas-enviam-mensagens-no-whatsapp-se-passando-por-entidades-do-governo (acesso em 16 out. 2026).

CISC Gov.br / CTIR Gov. Campanha tem como alvo domínios .gov.br, publicado em 3 mar. 2026, modificado em 8 abr. 2026. https://www.gov.br/cisc/pt-br/alertas-de-ciberseguranca/campanha-tem-como-alvo-dominios-gov.br (acesso em 16 out. 2026).

CISA. Implementing Phishing-Resistant MFA, fact sheet. https://www.cisa.gov/sites/default/files/2023-01/fact-sheet-implementing-phishing-resistant-mfa-508c.pdf (acesso em 16 out. 2026).

CISA. Phishing General Security Postcard. https://www.cisa.gov/sites/default/files/2024-02/Update%20to%20Phishing%20General%20Security%20Postcard_01.01.2024.pdf (acesso em 16 out. 2026).

Material de conscientização para público geral. Os exemplos são ilustrativos; procedimentos de resposta podem variar por serviço e política organizacional. Em caso de incidente no trabalho, siga o fluxo interno.